Nätverkssäkerhet

Föreläsning 7 – Endpoint- och LAN-säkerhet

Planering

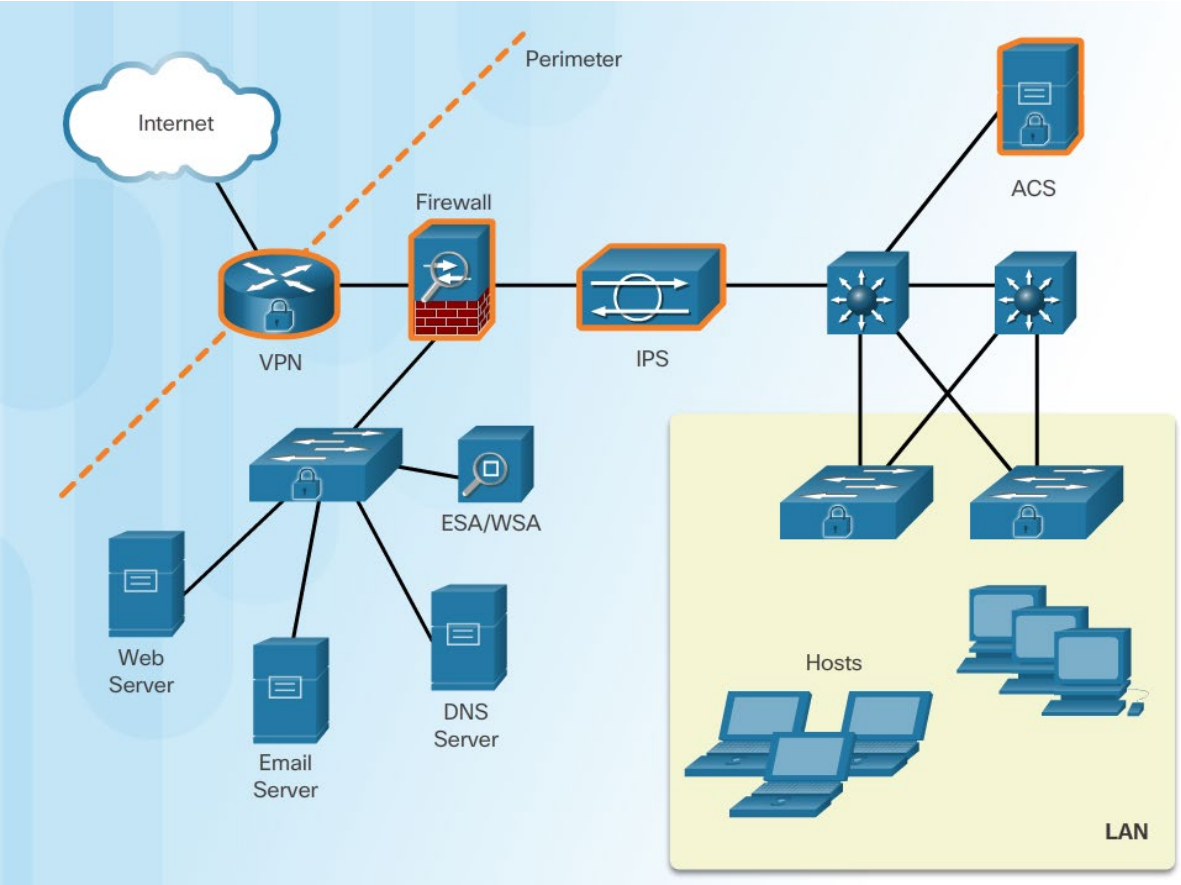
Vecka	Dag	Moment
35	Mån	~~**Föreläsning –** Kursintroduktion & introduktion till nätverkssäkerhet~~
	-	~~**Videoföreläsningar –** Säkra upp enheter & AAA~~
	Mån /Tis	~~**Laboration 1**~~
36	Mån	~~**Forts. Laboration 1**~~
	Tis	~~**Dugga 1** (09.00)~~
	Tor	~~**Gästföreläsning Fortinet**~~
	Fre	~~**Föreläsning –** Introduktion till brandväggar~~
37	Mån	~~**Laboration 2**~~
	Tis	~~**Dugga 2** (09.00)~~
	Tis	~~**Föreläsning –** IDS/IPS~~
38	Mån	~~**Laboration 3**~~
	Tis	~~**Dugga 3** (09.00)~~
	Tis	~~**Gästföreläsning JSC (09.30) &** **Föreläsning** – LAN- och endpoint-säkerhet~~
	Fre	**NFK-introduktion**
39	Mån	**Laboration 4**
	Tis	**Dugga 4** (09.00)
	-	**Videoföreläsning** – Kryptografi
	Tor	**Föreläsning** – VPN
40	Mån	**Laboration 5**
	Tis	**Dugga 5** (09.00)
	Tis	**Föreläsning** – Extrapass
41	Ons	**Laboration 6 & Redovisningar av Laboration 6**
42	-	**Tentavecka**

Halvtidsutvärdering

- **Medelbetyg:** 6.86 (på 7 svar)
- **Att förbättra:**
  - Inget???
- **Att fortsätta med:**
  - Allt???

Säkra upp det lokala nätverket

- Inget nätverk är säkrare än den svagaste länken, man får därför inte missa att säkra upp:
  - Klienter och servrar (endpoints)
  - Nätverksinfrastruktur på lager 2 (t.ex. switchar)
- Detta är en utav de viktigaste delarna för att säkra upp sitt interna nätverk



Endpoint Security

- Klassisk endpoint security:
  - HIPS (Host-based IPS)
  - Brandvägg (Host-based Firewall)
  - Antivirus och antimalware
- Bör man använda ett tredjeparts-antivirus?

The Borderless Network

- Kommer ni ihåg från CCNA?
- *Borderless Networks* är nätverk utan tydliga gränser:
  - BYOD (Bring Your Own Device)
  - Surfplattor, smartphones
  - Teleworking (jobba hemifrån)
- Borderless Networks har skapat helt nya säkerhetskrav på moderna nätverk

Gränsen för moderna nätverk

- I och med intåget av mobila enheter har gränsen för ett företags nätverk ändrats drastiskt
- En trend som har funnits länge är **BYOD (Bring Your Own Device)**
- **MDM (Mobile Device Management)** är flertalet metoder för att säkra, övervaka och styra mobila enheter i en företagsmiljö. Består av:
  - Kryptering av data
  - Policykrav på t.ex. PIN-kod
  - Rensning av enhet på distans
  - DLP-funktioner
  - Jailbreak/root-blockering

Säkra upp endpoints i *Borderless Network*

- Antivirus & antimalware
- EDR (Endpoint Detection and Response)
- DLP (Data Loss Prevention)
- SPAM-filtrering
- Blocklisting
- URL-filter
- NAC
- Sandbox

Moderna lösningar (…från Cisco)

- **AMP** (Advanced Malware Protection)
- **ESA** (Email Security Appliance)
- **WSA** (Web Security Appliances)
- **NAC** (Network Admission Control)

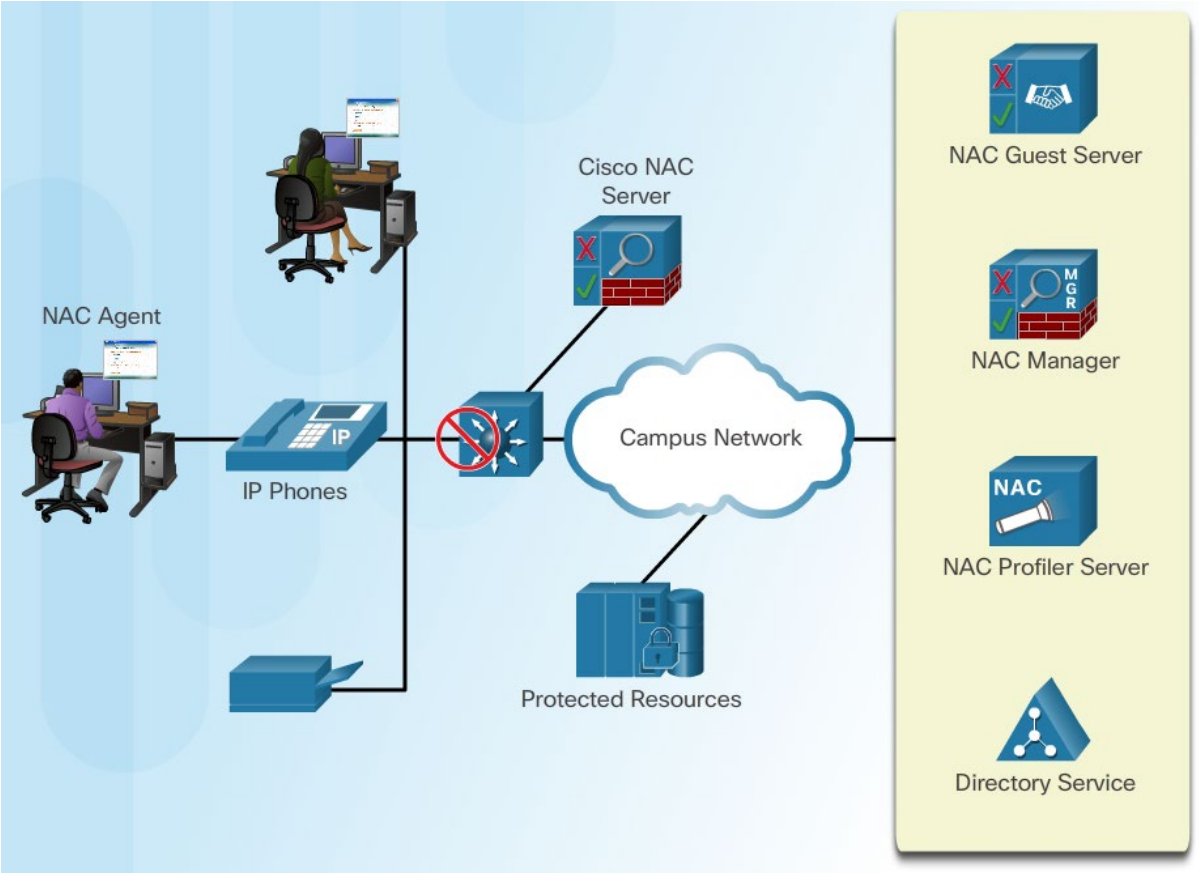
Säkra upp mail och webb

- **ESA** (Email Security Appliance)
  - Skyddar mot spam och malware
  - Kollar även utgående mail från företaget
- **WSA** (Web Security Appliance)
  - Kontrollerar URL-filtrering, och analys av produktivitetsrisker(?)
  - DLP (Data Loss Prevention), se till att skyddad data inte lämnar nätverket
  - Körs ofta som en appliance i ESXi
- Alla tjänsterna är kopplade mot Ciscos moln

Cisco Network Admission Control (NAC)

- NAC används för:
  - Känna igen användare, enheter och deras roll i nätverket (ofta via AAA)
  - Evaluera om enheter följer policy
  - Utföra åtgärder om policys inte följs
  - Enkel och säker gästhantering
  - Bokföring och rapporter på nätverksanvändningen
- Bygger på 802.1x

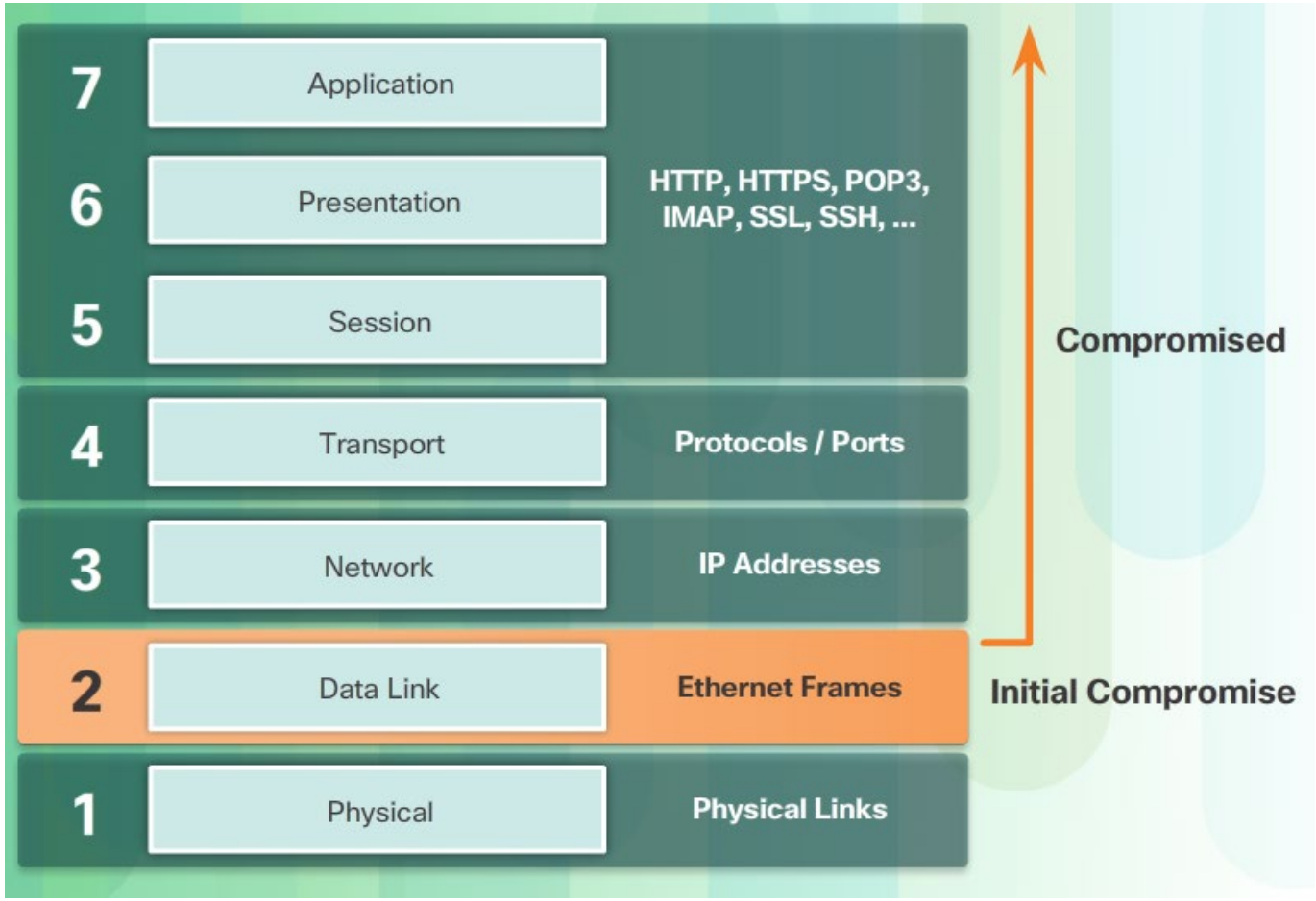
NAC-komponenter



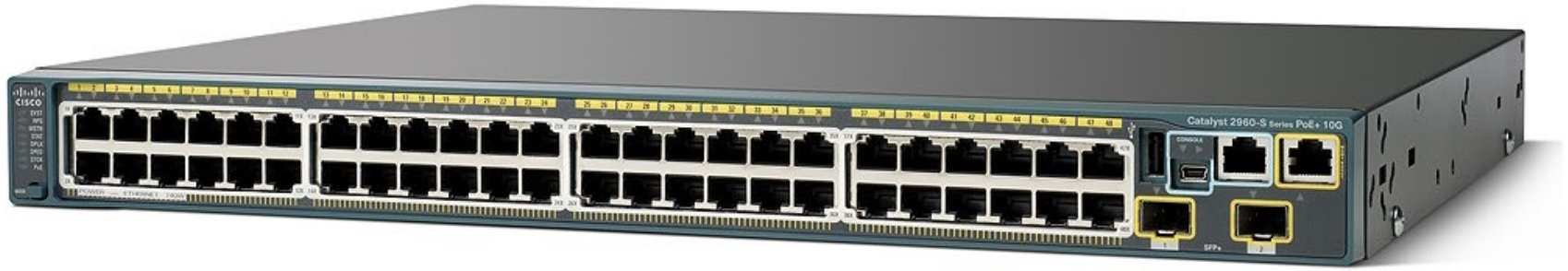
Kryptera enheter

- Enheter som tas utanför företaget kan bli stulna och tappade
- För att skydda informationen kan man kryptera lagringsmediet
- Olika tekniker:
  - BitLocker
  - VeraCrypt

Lager 2


7
Application
6
Presentation
5
Session
HTTP, HTTPS, POP3, IMAP, SSL, SSH, ...
4
Transport
Protocols / Ports
3
Network
IP Addresses
2
Data Link
Ethernet Frames
1
Physical
Physical Links
Compromised
Initial Compromise

Vad gör en switch?



Hur vet switchen vilken port den ska skicka ut en frame på?

Port Table

Destination Addresses	Port
EE	1
AA	2
BA	3
EA	4
AC	5
AB	6

Hur lär den sig adresser?

Port Table

Destination Addresses	Port
EE	1
AA	2
BA	3
EA	4
AC	5
AB	6

Inte att blanda ihop med: ARP

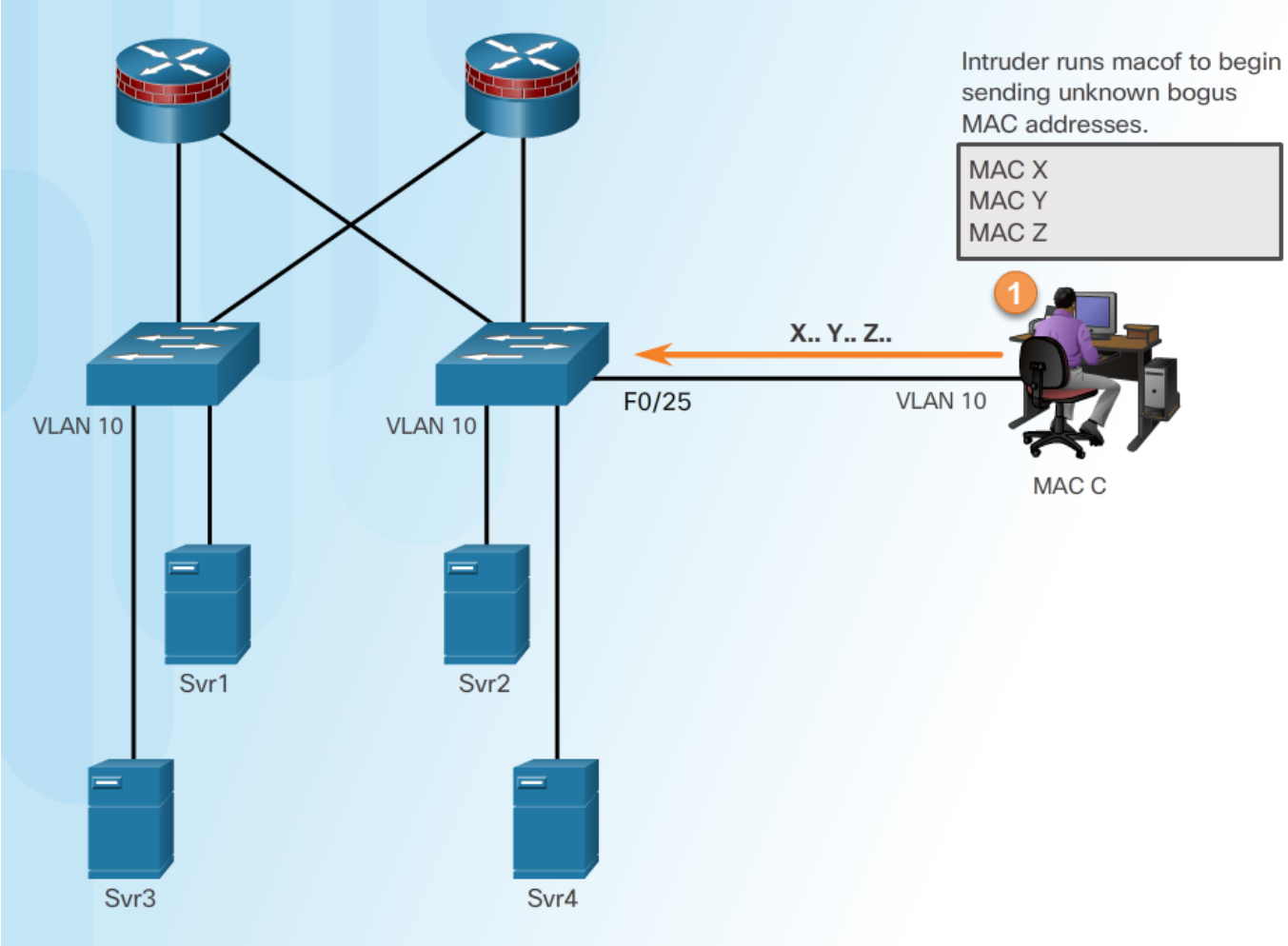
- ARP används på klienter(!) för att koppla IP-address till MAC-address
- ARP används inte på switchar för att skapa MAC-adresstabell (CAM)
- Olika typer av paket:
  - ARP Request
  - ARP Reply

Attacker på lager 2

- **CAM-attacker**
  - Attacker mot Content-addressable memory (CAM)
- **STP-attacker**
  - Manipulation av Spanning-Tree Protocol (STP)
- **VLAN-attacker**
  - Inkluderar VLAN hopping och VLAN double-tagging
- **Address Spoofing-attacker**
  - Spoofing av MAC och/eller IP
- **DHCP-attacker**
  - Inkluderar bland annat DHCP starvation och DHCP spoofing
- **ARP-attacker**
  - Inkluderar ARP spoofing

Attack mot CAM-tabellen

- Felaktiga MAC-adresser läggs till i CAM-tabellen
- Ett attackverktyg (pentesting) är **macof**
- När tabellen är full skickas frames ut på alla portar i samma VLAN



Port Security

- Ett sätt att skydda sig mot CAM-tabellattacker är **Port security**
- **Port security** kan användas för att begränsa antalet source-MAC som tillåts på en port. Konfiguration:

```
S1(config)# interface gi0/0
S1(config-if)# switchport port-security
```

- Med standardinställningar tillåts endast 1 MAC samtidigt, vid överträdelse stängs porten av. För att öka detta:

```
S1(config-if)# switchport port-security maximum 5
```

Port Security

- Det går också ställa in statiskt vilka MAC-adresser som tillåts på porten:

```
S1(config-if)# switchport port-security mac-address abcd.abcd.abcd
```

- Alternativt kan switchen lära sig MAC-adresser dynamiskt och spara:

```
S1(config-if)# switchport port-security mac-address sticky
```

Port Security Aging

- Port Security Aging är den tiden som en MAC-adress sparas
- Indelat i två delar; *absolute* och *inactivity*
  - **Absolute** – Efter en viss tid tas adressen bort
  - **Inactivity** – Efter inaktivitet i en viss tid tas adressen bort
- Konfiguration enligt nedan:

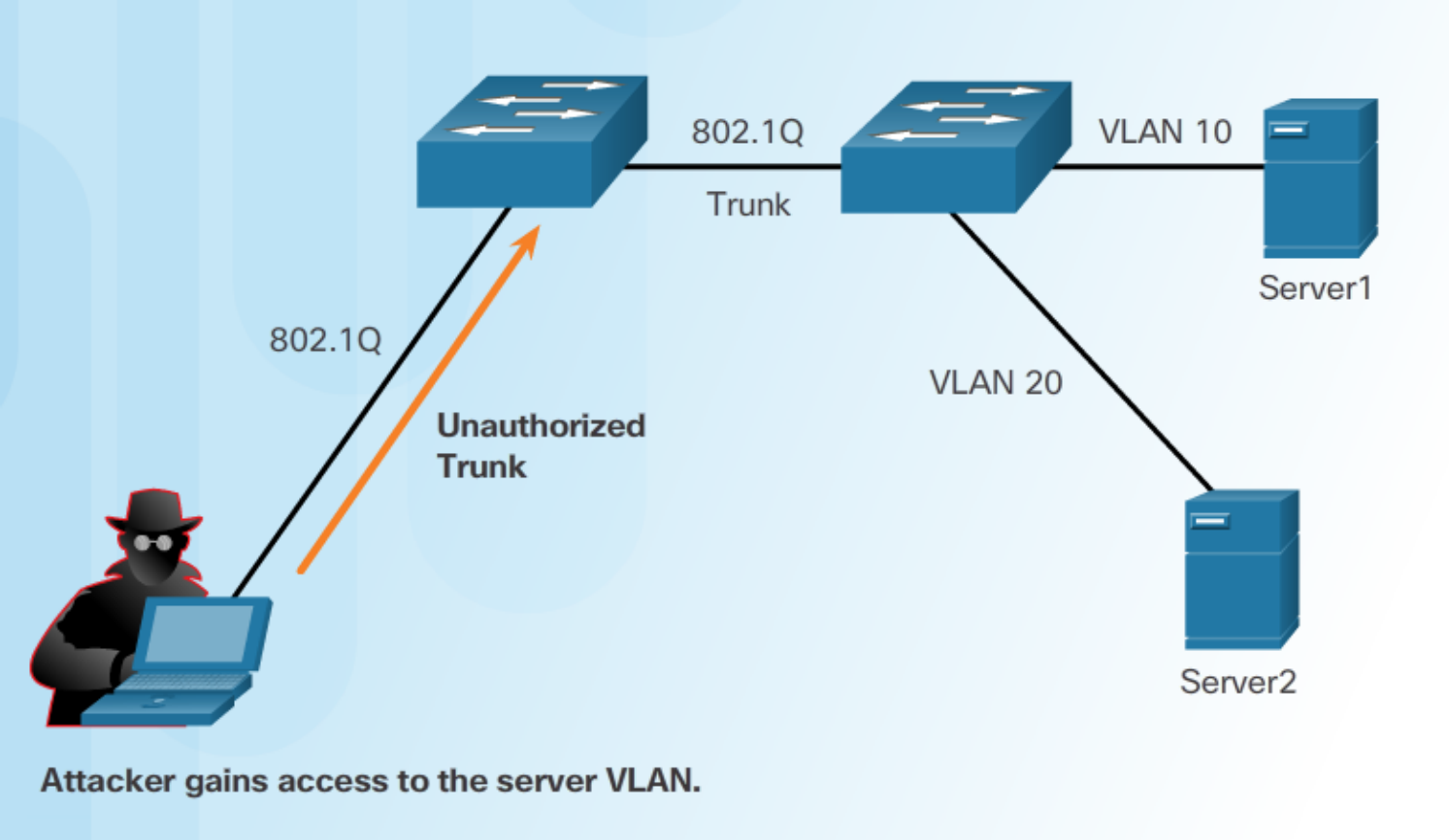
```
S1(config-if)# switchport port-security aging time 10
S1(config-if)# switchport port-security aging type inactivity
```

Port Security Violations

- Vid en överträdelse finns tre olika *violations;*
- **Protect**
  - Minst säker
  - Vid en överträdelse slängs frames från den okända MAC-adressen
  - Ingen notifikation skickas till administratören
- **Restrict**
  - Samma som *protect* med tillägget att en notifikation skickas till administratören
- **Shutdown**
  - Standardläge och det säkraste
  - Vid en överträdelse blir porten ***error-disabled***

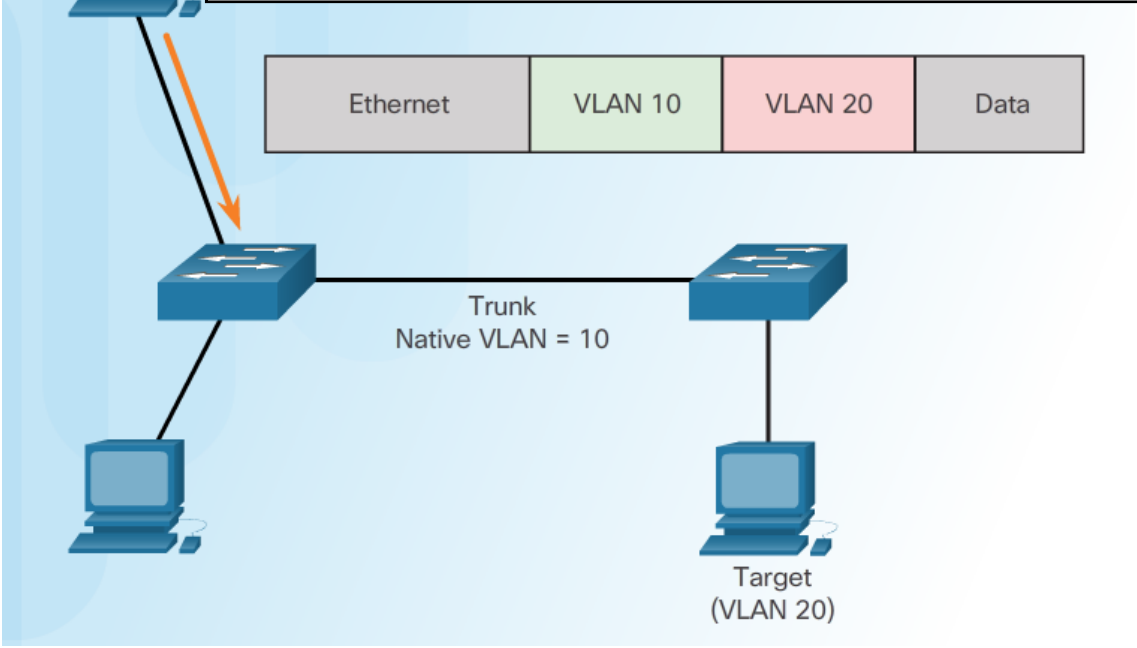
VLAN-attacker

- VLAN är ett ovärderligt verktyg i moderna nätverk, det finns dock vissa säkerhetsrisker
- **VLAN Hopping** handlar om att komma åt andra VLAN än det som man är ansluten mot
- Detta möjliggörs via **DTP** (Dynamic Trunking Protocol)
  - Extra switch
  - Klient skickar DTP



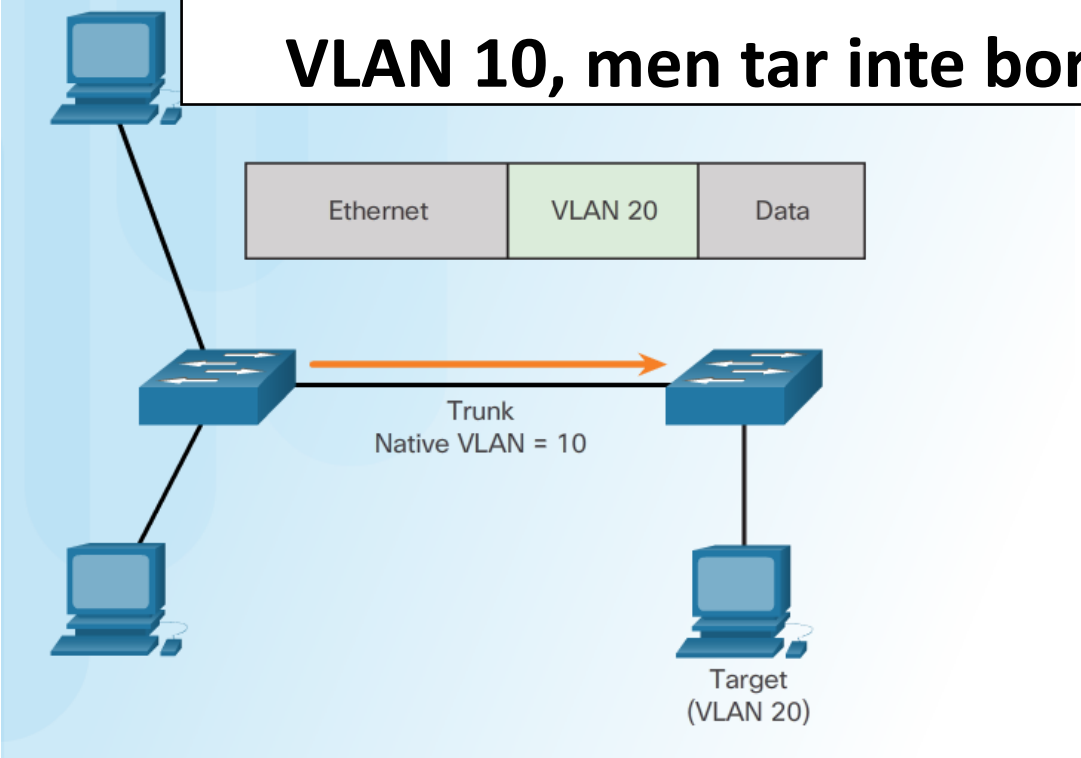
VLAN Double Tagging Attack

En hacker sitter på VLAN 10. En frame taggas för VLAN 10 och en för VLAN 20

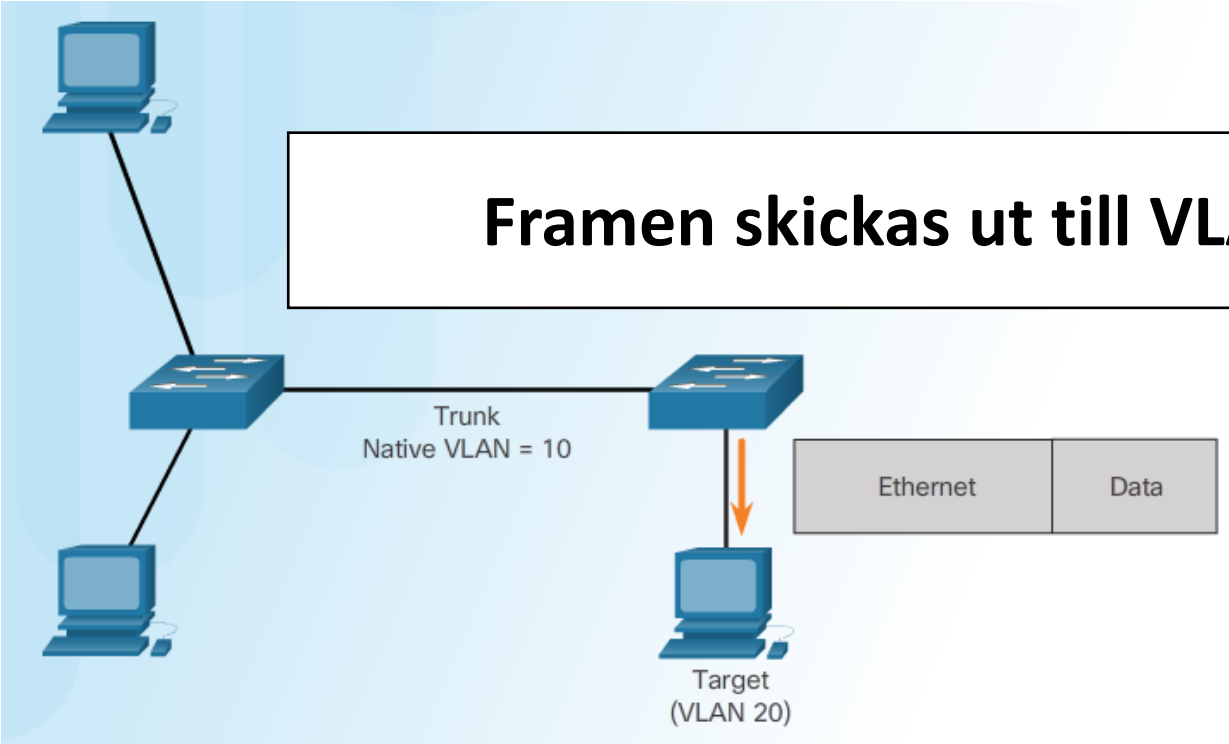


VLAN Double Tagging Attack

Den första switchen tar bort taggen för VLAN 10, men tar inte bort VLAN 20



VLAN Double Tagging Attack



Framen skickas ut till VLAN 20

Motverka VLAN-attacker

- **VLAN Hopping**:
  - Använd bara access-port i statiskt läge

```
S1(config-if)# switchport mode access
```

  - Använd bara trunk i statiskt läge

```
S1(config-if)# switchport mode trunk
```

  - Förhandlingar går även stänga av med:

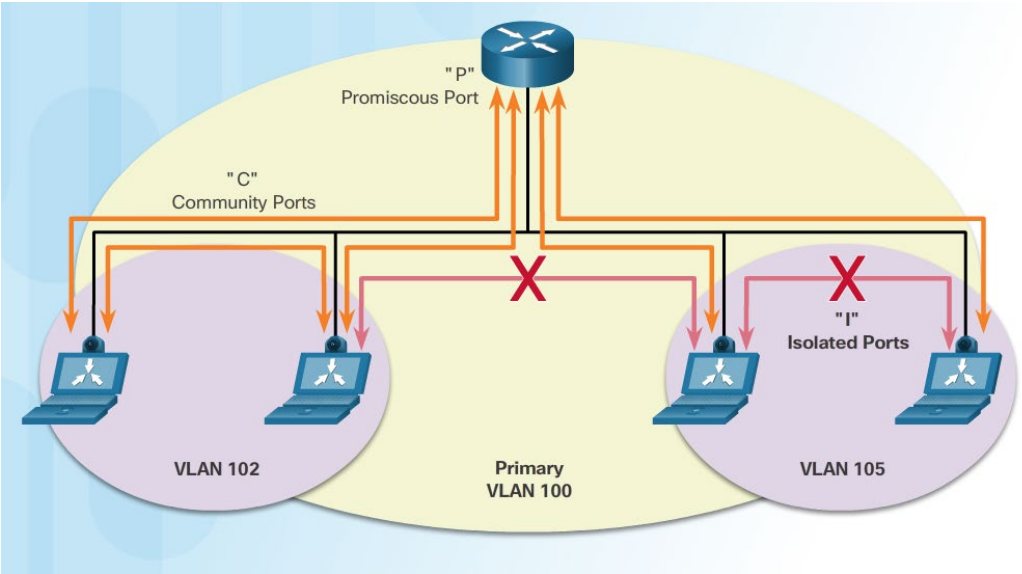
```
S1(config-if)# switchport nonegotiate
```

- **VLAN Double Tagging**:
  - Stäng av oanvända portar och sätt dem i ett eget VLAN
  - Sätt Native VLAN till ett helt eget VLAN

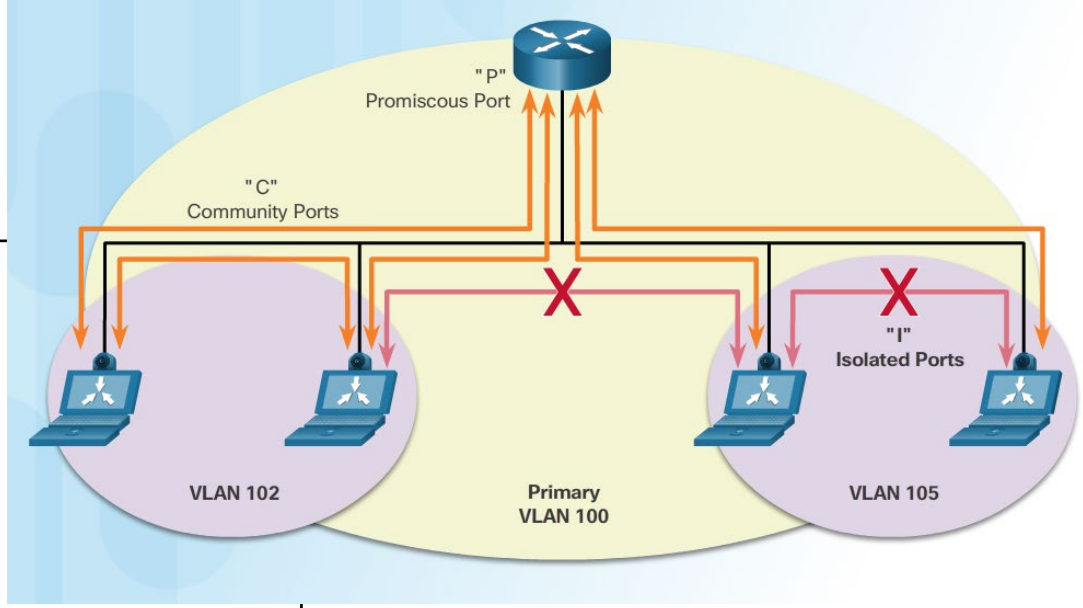
```
S1(config-if)# switchport trunk native vlan 99
```

Private VLAN (mikrosegmentering)

- **Private VLAN** definierar olika roller för att skydda kommunikation mellan portar
- I Private VLAN finns tre olika port-typer:
  - **Promiscuous** – Kan kommunicera med alla
  - **Isolated** – Kan bara prata med *Promiscuous*
  - **Community** – Kan prata med andra *Community* samt *Promiscuous*
- I labbet görs Private VLAN på switchar i 3500- eller 3600-serien



Private VLAN – Konfiguration

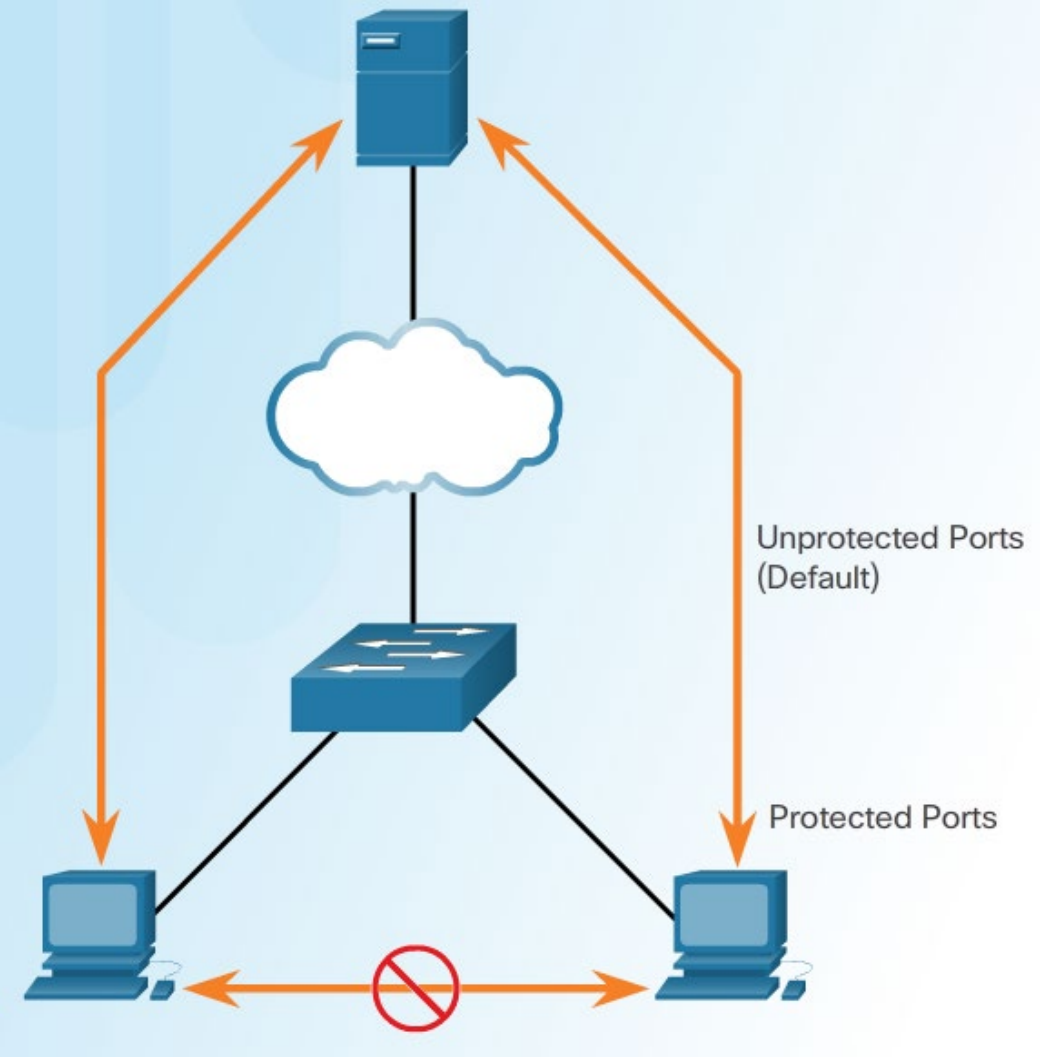



```
S1(config)# (feature private-vlan)
S1(config)# vlan 100
S1(config-vlan)# private-vlan primary
S1(config-vlan)# private-vlan association 102, 105
S1(config-vlan)# vlan 102
S1(config-vlan)# private-vlan community
S1(config-vlan)# vlan 105
S1(config-vlan)# private-vlan isolated
S1(config-vlan)#
S1(config-vlan)# int range gi0/1-10
S1(config-if)# switchport mode private-vlan host
S1(config-if)# switchport private-vlan host-association 100 102
S1(config-vlan)# int range gi0/11-15
S1(config-if)# switchport mode private-vlan host
S1(config-if)# switchport private-vlan host-association 100 105
S1(config-if)# int gi0/24
S1(config-if)# switchport mode private-vlan promiscuous
S1(config-if)# switchport private-vlan mapping 100 102,105
```

Private VLAN Edge (Protected port)

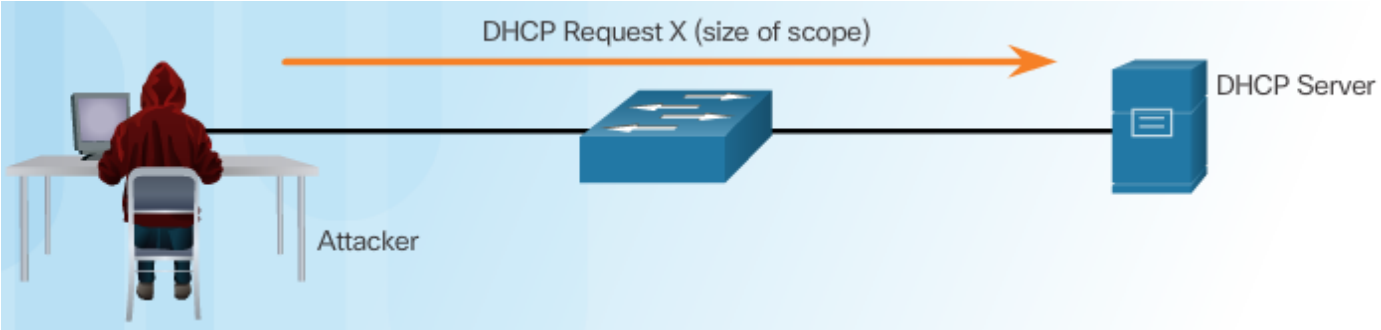
- **Private VLAN Edge** är en enkel funktion för **Private VLAN**
- Portar som är satta i *PVLAN Edge* kan inte kommunicera med andra portar satta i läget
- Portar som är satta i *PVLAN Edge* kan kommunicera med portar utan funktionen
- Konfiguration av port:

```
S1(config-if)# switchport protected
```



DHCP Starvation

- Som namnet antyder innebär det att DHCP-servern *scope* fylls upp av skräputlåningar
- Eftersom *scopet* töms räknas det som en DoS-attack



DHCP Spoofing

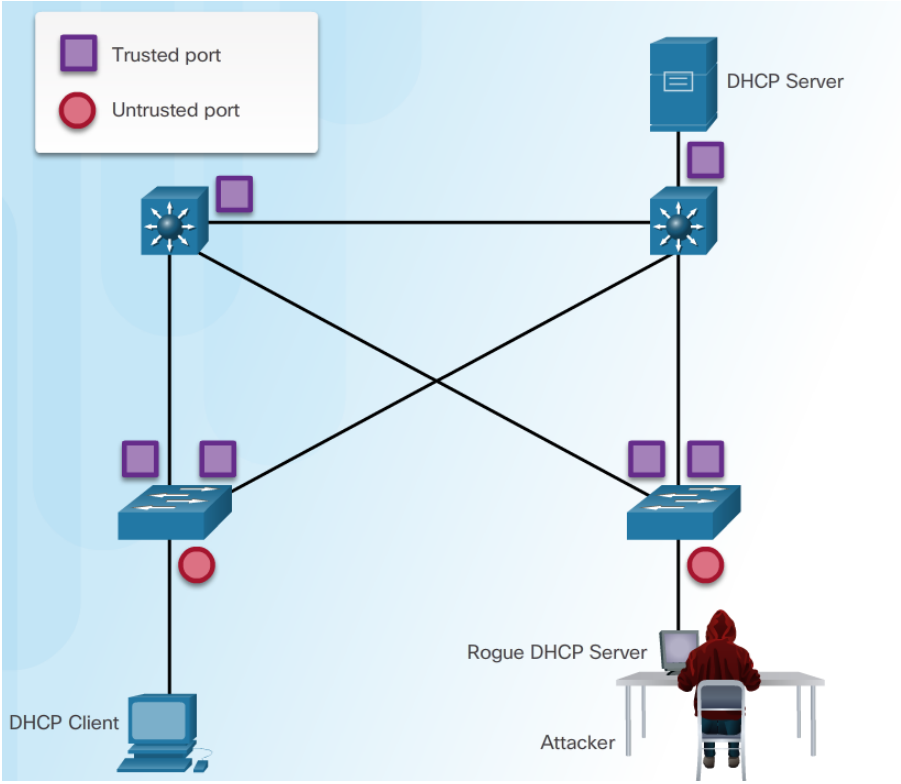
- Innebär att någon sätter upp en otillåten DHCP-server i nätverket
  - Finns både medvetna och omedvetna varianter
- Servern kan genom att göra detta exempelvis ändra:
  - Default gateway (MITM)
  - DNS-server (typ MITM)
  - IP-adress (DoS)

Motverka DHCP-attacker

- **DHCP starvation**
  - Löses enkelt genom att implementera **port security**
- **DHCP spoofing**
  - Motverkas med **DHCP snooping**

DHCP Snooping

- Portar ställs i *trusted* och *untrusted*
- *Trusted* sätts mot DHCP-servern samt på upplänksportar mot servern
- Går också att ställa in *rate limit* i DHCP Snooping för att motverka *DHCP Starvation*, effektivast är dock att använda *Port Security*



DHCP Snooping - Konfiguration

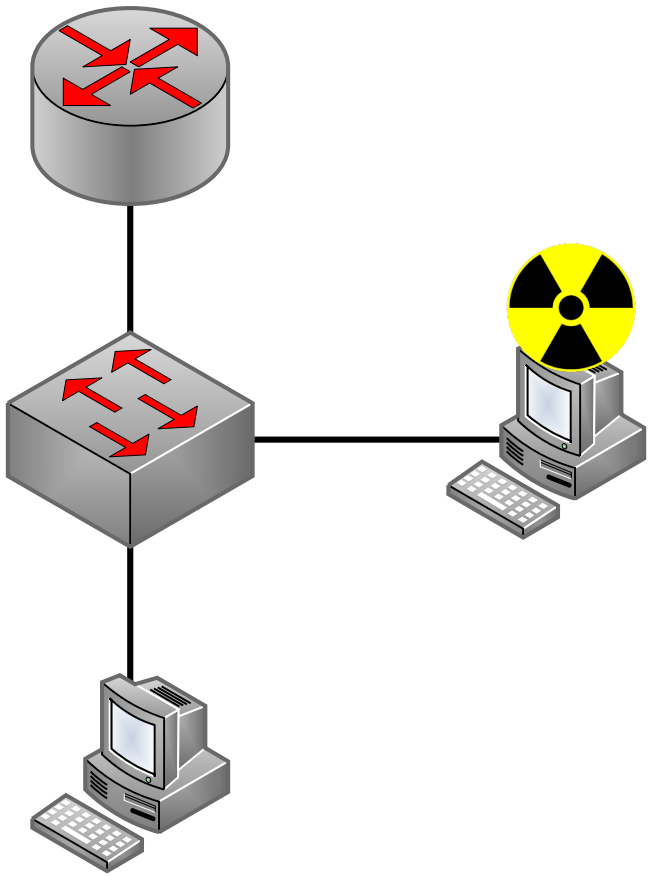
- **Steg 1:** Sätt igång DHCP Snooping globalt
- **Steg 2:** Ställ in vilka portar som är *trusted*
- **Steg 3:** Sätt igång DHCP Snooping på berörda VLAN

```
S1(config)# ip dhcp snooping
S1(config)# interface g0/1
S1(config-if)# ip dhcp snooping trust
S1(config-if)# exit
S1(config)# ip dhcp snooping vlan 10,20-23
```

- Felsök och verifiera med **debug ip dhcp snooping…**

ARP Spoofing/Poisoning

- **ARP** används för att översätta från IP-adress till MAC-adress för kommunikation i det lokala nätverket
- Bygger på att man spoofar en **Gratuitous ARP** där man säger att MAC-adressen för exempelvis default gateway har ändrats
- Detta i sin tur blir vanligtvis en **MITM** (Man-in-the-Middle)-attack där alla trafik går via hackerns dator innan det går ut via routern
- Verktyg: Cain & Abel (Windows), arpspoof (Linux)



Dynamic ARP Inspection (DAI)

- För att skydda sig kan man använda sig av **DAI**
- Bygger på DHCP Snooping (tabellerna som är skapade används av DAI)
- Sätt trust mellan switchar och mot router

```
S1(config)# ip dhcp snooping
S1(config)# interface g0/1
S1(config-if)# ip dhcp snooping trust
S1(config-if)# ip arp inspection trust
S1(config-if)# exit
S1(config)# ip dhcp snooping vlan 10
S1(config)# ip arp inspection vlan 10
```

- Alternativt kan man skapa ARP-ACL:er

Address Spoofing

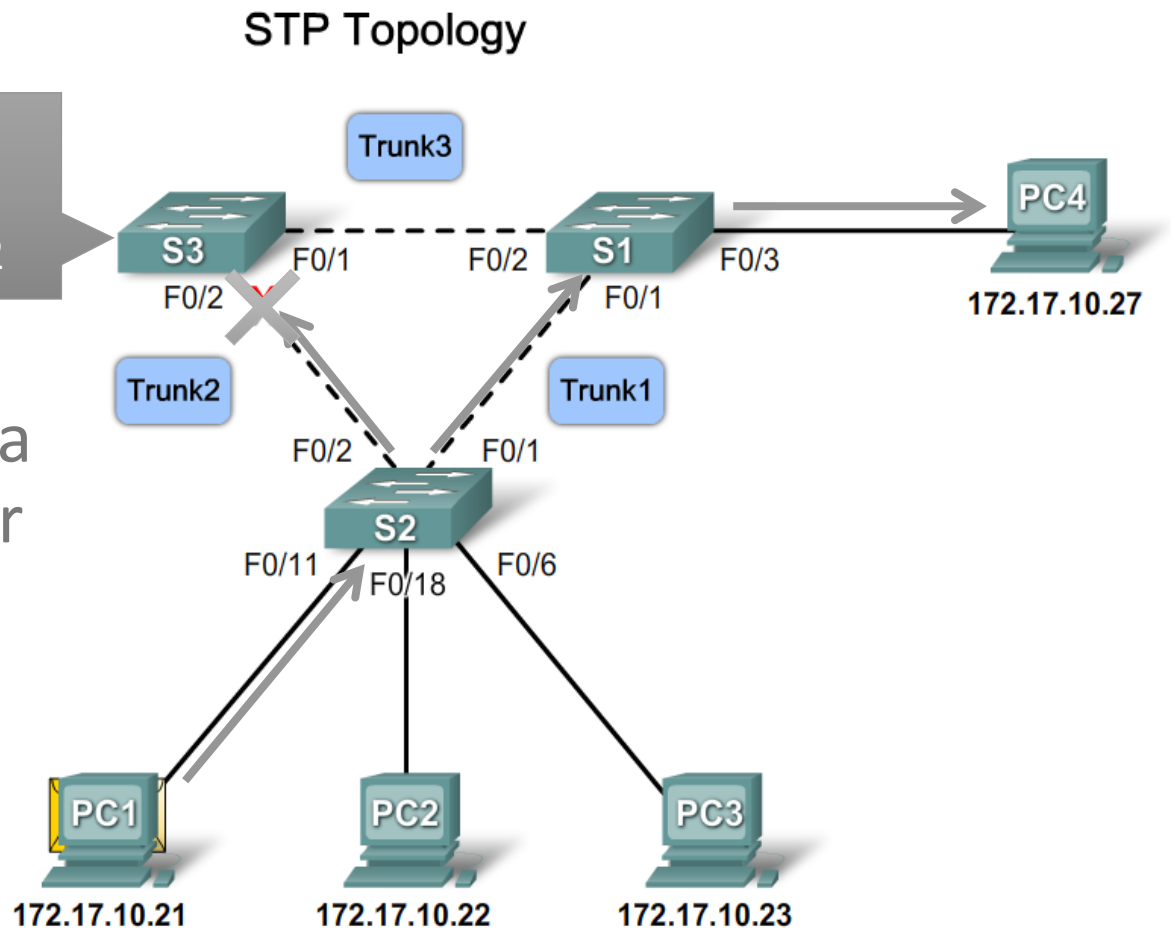
- Address Spoofing innebär att man ändrar sin adress till en som redan används i nätverket för att få ta del av paket
- Skydd mot detta görs med IP Source Guard som skyddar både mot MAC- och IP-adressattacker
- För att skydda sig behöver man även här tillgång till DHCP Snooping

```
S1(config)# interface g0/1
S1(config-if)# ip verify source
```

Spanning Tree Protocol (STP)

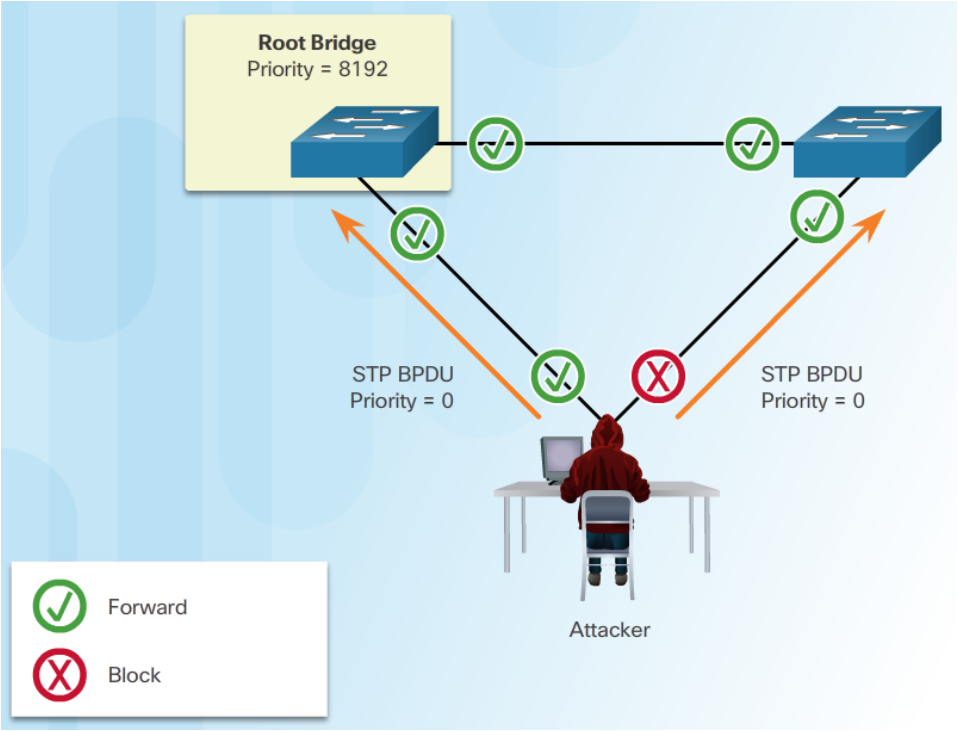
- STP används för att förhindra loopar i lager 2
- STP utser en rootbrygga för det lokala nätverket och stänger parallella vägar till den bryggan

BLOCKED PORT!
S3 kastar frames inkommande på F0/2



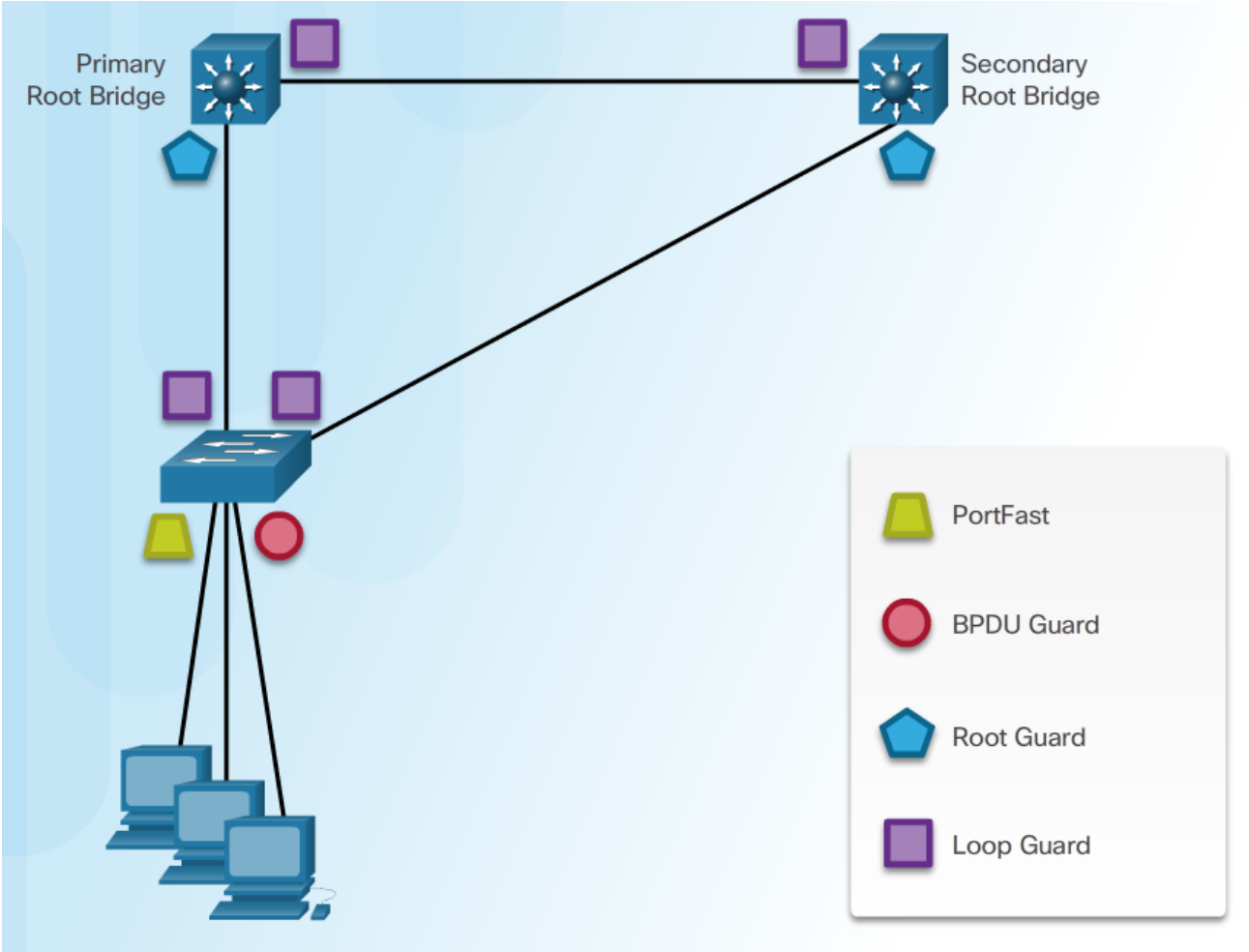
Manipulation av STP-processen

- Genom att skicka egensnickrade BPDU:er kan en hacker bli rootbrygga i nätverket



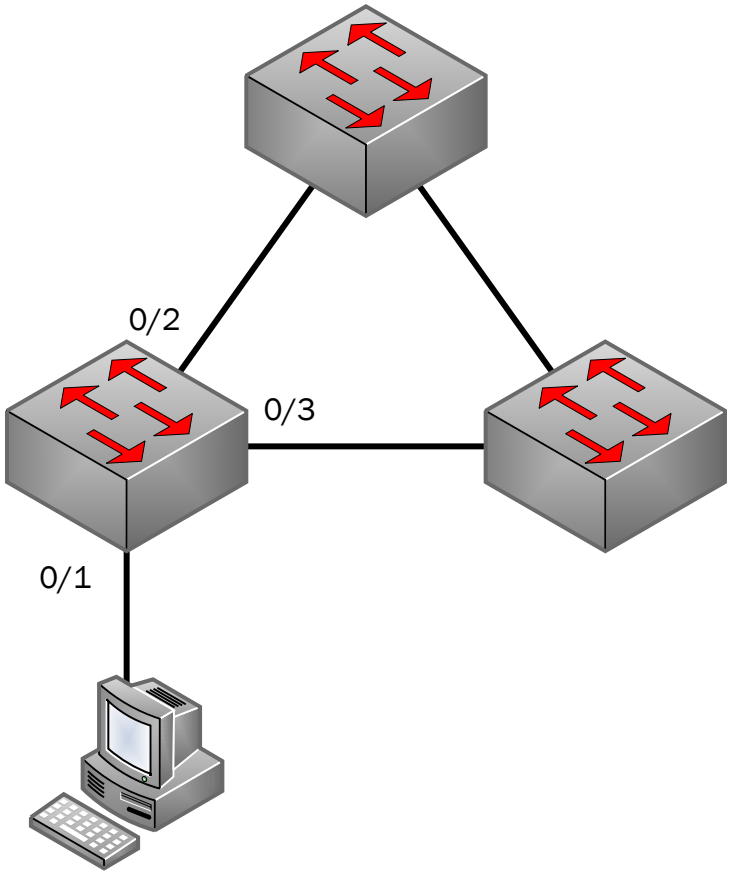
Motverka STP-attacker

- **BPDU guard**
  - Inskickad BPDU gör att porten blir err-disabled
- **Root guard**
  - Skyddar mot att en olämplig switch blir root
  - Sätt endast på root-brygga
- **Loop guard**
  - Skyddar mot loopar på felande non-designated-portar
  - Sätt på alla portar mellan switchar
- **(PortFast)**
  - Snabb anslutning för klienter



Konfiguration av STP-skydd

```
! Konfiguration av PortFast på klientport
S1(config)# int gi0/1
S1(config-if)# spanning-tree portfast
! PortFast som default-inställning
S1(config)# spanning-tree portfast default
! Konfiguration av BPDU Guard på klientport
S1(config)# int gi0/1
S1(config-if)# spanning-tree bpduguard enable
S1(config-if)# errdisable recovery cause bpduguard
S1(config-if)# errdisable recovery interval 30
! Konfiguration av Root Guard mot ”okända” switchar
S1(config)# int gi0/2
S1(config-if)# spanning-tree guard root
! Konfiguration av Loop Guard mot betrodda switchar
S1(config)# int gi0/3
S1(config-if)# spanning-tree guard loop
```



kahoot.it

JÖNKÖPING UNIVERSITY

School of Engineering